BILLOGRAPH

CAHIER DES CHARGES

Administration centralisée, gestion des rôles et sécurisation du projet

Propriétaire unique et Super Administrateur

HOUEDJISSI JUDES B.

Document de référence destiné à la conception, à l’amélioration ou à l’implémentation du système d’administration de la plateforme BILLOGRAPH.

Version 1.0 — Octobre 2026

1. Présentation du projet

BILLOGRAPH est une plateforme destinée à faciliter la création, l'hébergement, la commercialisation et la livraison de produits numériques. Son administration doit permettre à plusieurs collaborateurs d'effectuer leurs missions avec des comptes individuels, tout en protégeant la propriété, les revenus, les données, les moyens de paiement et les accès techniques du projet.

2. Objectifs du cahier des charges

- Créer un compte distinct pour chaque membre de l'équipe.
- Attribuer automatiquement des permissions de départ en fonction du poste ou du rôle.
- Permettre au propriétaire de modifier précisément les permissions depuis le panneau d'administration.
- Séparer les opérations quotidiennes des actions critiques qui peuvent affecter la propriété, les finances ou la sécurité.
- Empêcher tout membre, y compris le Greffier principal, de s'octroyer des privilèges supérieurs ou de prendre le contrôle du projet.
- Conserver une trace vérifiable des actions importantes et permettre la révocation rapide des accès.

3. Principes fondamentaux

3.1 Propriété et contrôle

- HOUEDJISSI JUDES B. est l'unique propriétaire désigné et l'unique compte SUPER_ADMIN.
- Le rôle SUPER_ADMIN ne peut être attribué, transféré, recréé ou modifié par aucun autre compte.
- Aucun collaborateur ne peut modifier l'identité, l'adresse de connexion principale, les facteurs de récupération ou les moyens de récupération du compte propriétaire.
- Les changements de propriété, de contrôle du domaine, de dépôt de code, d'hébergement, de comptes de paiement ou d'actifs essentiels nécessitent une action du propriétaire et, lorsque pertinent, une confirmation indépendante auprès du fournisseur concerné.

3.2 Principe du moindre privilège

Chaque utilisateur ne reçoit que les accès indispensables à son travail. Les permissions sont refusées par défaut lorsqu'elles ne sont pas explicitement accordées. L'interface doit masquer les actions non autorisées, mais cette mesure visuelle ne remplace jamais le contrôle des permissions côté serveur.

3.3 Séparation des tâches

Les actions sensibles doivent distinguer au minimum la consultation, la préparation, l'approbation, l'exécution et le rapprochement. Une même personne ne doit pas pouvoir initier et approuver seule une opération financière critique lorsque le niveau de risque justifie une double validation.

4. Hiérarchie et rôles

4.1 Propriétaire — SUPER_ADMIN

- Accès complet à la configuration de la plateforme et à la gestion des permissions.
- Création, modification, suspension et réactivation des comptes administratifs.
- Configuration des rôles, des règles de sécurité et des seuils de validation.
- Accès aux paramètres critiques, aux rapports et aux journaux d'audit.
- Seul rôle autorisé à accorder ou retirer les permissions réservées au propriétaire.
- Possibilité de révoquer immédiatement les sessions et les accès de tous les autres utilisateurs.

4.2 Greffier principal — GREFFIER_PRINCIPAL

Le Greffier principal assiste le propriétaire dans la coordination et la supervision de l'administration. Il dispose de pouvoirs opérationnels étendus, mais ne doit jamais posséder les capacités de propriété ou de contrôle ultime.

- Peut consulter les tableaux de bord administratifs et superviser les opérations autorisées.
- Peut gérer les comptes ordinaires et attribuer des rôles prédéfinis dans les limites définies par le propriétaire.
- Peut consulter les rapports financiers si cette permission lui est accordée.
- Peut préparer des opérations sensibles et soumettre une demande d'approbation.
- Ne peut pas devenir SUPER_ADMIN, modifier le compte propriétaire ou changer les permissions réservées au propriétaire.
- Ne peut pas modifier seul les coordonnées de paiement, les comptes bancaires, les clés API critiques, les commissions fondamentales ou les paramètres de propriété.
- Ne peut pas exécuter seul les opérations financières réservées à une double validation.
- Ne peut pas effacer les journaux d'audit, désactiver leur collecte ou modifier rétroactivement les traces.
- Ne peut pas transférer le domaine, le dépôt de code, l'hébergement, les actifs numériques ou la propriété de BILLOGRAPH.

4.3 Directeur général

- Suivi des opérations et des indicateurs de performance.
- Consultation des rapports nécessaires à la direction.
- Coordination des équipes et gestion des tâches, selon les permissions accordées.
- Aucun accès automatique aux secrets techniques, aux clés de paiement ou au compte propriétaire.

4.4 Programmeur

- Accès aux environnements de développement et de test nécessaires.
- Gestion du code selon les droits accordés et les processus de validation.
- Aucun accès de production ou secret de paiement par défaut.
- Les déploiements en production doivent être contrôlés, journalisés et protégés par une procédure de validation.

4.5 Responsable cybersécurité

- Consultation des alertes, événements de sécurité et journaux nécessaires à sa mission.
- Gestion des contrôles de sécurité autorisés et recommandations correctives.
- Aucun pouvoir de suppression des traces d'audit ni de modification du propriétaire.
- Les tests intrusifs doivent être autorisés et réalisés dans un périmètre défini.

4.6 Community Manager

- Gestion des contenus, publications, messages et interactions sur les canaux autorisés.
- Aucun accès par défaut aux finances, aux paramètres de propriété ou aux données sensibles des vendeurs.

4.7 Responsable publicité

- Gestion des campagnes, audiences, créations et statistiques publicitaires autorisées.
- Accès au budget publicitaire uniquement selon une limite définie.
- Toute augmentation de plafond ou dépense exceptionnelle doit suivre la procédure d'approbation.

4.8 Monteur vidéo

- Accès aux ressources créatives et aux espaces de livraison nécessaires.
- Aucun accès automatique aux comptes administratifs, aux paiements ou aux données privées des clients.

4.9 Comptable

- Consultation des transactions, commissions, rapports et justificatifs autorisés.
- Préparation des rapprochements et rapports financiers.
- Aucun droit automatique de modifier les soldes des vendeurs, les transactions confirmées ou les coordonnées de paiement.
- Les remboursements, ajustements et opérations sensibles doivent être approuvés et tracés.

4.10 Secrétariat

- Gestion des documents, communications et tâches administratives autorisées.
- Accès limité aux informations personnelles et confidentielles strictement nécessaires.
- Aucun accès financier ou technique privilégié par défaut.

5. Permissions et personnalisation

Le système doit utiliser un modèle RBAC (permissions liées aux rôles), complété par des permissions individuelles. Les permissions par défaut sont appliquées à la création du compte. Le propriétaire peut ensuite ajuster les permissions d'un utilisateur ou d'un rôle depuis l'administration.

- Afficher clairement les permissions héritées du rôle et les exceptions individuelles.
- Permettre d'accorder ou de retirer chaque permission sans devoir changer le poste de l'utilisateur.
- Ne jamais rétablir silencieusement les permissions par défaut lors d'une mise à jour.
- Enregistrer qui a modifié une permission, quand, pour quel compte, et quelle était la valeur précédente.
- Empêcher le Greffier principal et les autres rôles de modifier les permissions du SUPER_ADMIN ou de s'accorder des droits supérieurs aux limites fixées.
- Réévaluer les permissions effectives à chaque requête côté serveur.

5.1 Exemples de clés de permissions

- admin.users.view, admin.users.create, admin.users.update, admin.users.suspend
- admin.roles.view, admin.roles.assign, admin.permissions.customize
- finance.transactions.view, finance.reports.view, finance.reconciliation.prepare
- finance.refunds.prepare, finance.refunds.approve, finance.refunds.execute
- finance.payouts.view, finance.payouts.prepare, finance.payouts.approve, finance.payouts.execute
- settings.platform.view, settings.platform.update, settings.critical.update
- security.logs.view, security.sessions.revoke, security.settings.update
- content.manage, campaigns.manage, analytics.view

6. Sécurité financière

La protection financière est une exigence prioritaire. Les soldes des vendeurs, les transactions confirmées et les paiements doivent être traités comme des données comptables sensibles.

- Séparer les droits de consultation, préparation, approbation et exécution.
- Exiger une approbation du propriétaire pour les changements de coordonnées de paiement, les opérations exceptionnelles et les modifications de règles de commission ou de versement.
- Appliquer une double validation pour les opérations définies comme critiques.

- Ne jamais permettre à un administrateur de modifier directement un solde vendeur sans une opération d'ajustement formelle, justifiée, approuvée et journalisée.
- Conserver les identifiants de transaction du prestataire de paiement et effectuer les rapprochements avec les événements de paiement réels.
- Utiliser des clés d'idempotence et des contrôles contre les doubles paiements ou remboursements.
- Ne pas stocker les secrets de paiement dans le code source ni les afficher en clair dans les journaux.
- Limiter les montants et fréquences des opérations lorsque cela est pertinent.

7. Journal d'audit

Toute action sensible doit générer un événement d'audit horodaté et protégé contre l'altération. Le journal doit notamment enregistrer :

- Identifiant de l'utilisateur et rôle actif.
- Action effectuée, ressource concernée et résultat (succès ou échec).
- Date et heure, contexte de session et adresse IP lorsque légalement et techniquement approprié.
- Valeur précédente et nouvelle valeur pour les changements de configuration, en évitant d'y inclure des secrets.
- Motif ou référence de validation pour les opérations sensibles.

Les utilisateurs ordinaires ne peuvent pas supprimer ou réécrire ces journaux. L'accès à leur consultation doit lui-même être journalisé. Prévoir une politique de conservation et des sauvegardes protégées.

8. Authentification et sessions

- Compte individuel obligatoire : aucun partage de compte administratif.
- Authentification multifacteur obligatoire pour le propriétaire et recommandée ou exigée pour les rôles privilégiés.
- Mots de passe robustes, stockage avec hachage adapté, limitation des tentatives et protection contre les attaques par force brute.
- Expiration des sessions inactives, révocation à distance et affichage des sessions actives.
- Réauthentification pour les opérations critiques.
- Alertes en cas de connexion inhabituelle, changement de paramètres de sécurité ou élévation de privilèges.
- Procédure de récupération du compte propriétaire qui ne dépend pas d'un autre administrateur.

9. Protection des actifs et de l'infrastructure

- Le domaine, l'hébergement, les dépôts de code, les comptes cloud, les comptes de paiement et les comptes de publication doivent rester sous le contrôle du propriétaire ou d'entités qu'il contrôle.
- Utiliser des comptes nominatifs et des droits minimaux chez les fournisseurs externes.
- Séparer les environnements de développement, de test et de production.
- Stocker les secrets dans un gestionnaire de secrets ou dans les mécanismes sécurisés de l'hébergeur.
- Sauvegarder régulièrement la base de données et les fichiers critiques, chiffrer les sauvegardes et tester la restauration.
- Documenter les dépendances, accès fournisseurs, procédures de déploiement et contacts de récupération.
- Ne jamais placer une clé secrète dans le navigateur, une application cliente ou un dépôt public.

10. Tableau de bord du propriétaire

- Vue globale de l’activité, des utilisateurs et des indicateurs de vente.
- Gestion des comptes, rôles, permissions et sessions.
- Historique des changements et alertes de sécurité.
- Vue des transactions, commissions, remboursements et versements selon les besoins.
- Approbation ou rejet des demandes sensibles avec motif obligatoire.
- Gestion des paramètres critiques, des seuils de validation et des règles de sécurité.
- Fonction d’urgence pour suspendre un compte ou révoquer ses sessions.

11. Tableau de bord du Greffier principal

- Suivi des tâches administratives et demandes en attente.
- Gestion des comptes non propriétaires dans les limites autorisées.
- Consultation des rapports et journaux autorisés.
- Préparation et transmission des opérations sensibles pour approbation.
- Aucune commande pour transférer la propriété, modifier le compte propriétaire, supprimer les traces ou s’attribuer SUPER_ADMIN.

12. Suspension et départ d’un collaborateur

- Désactiver immédiatement le compte et révoquer toutes les sessions lors d’un départ ou d’un incident.
- Révoquer les jetons API, clés, invitations et accès aux services externes qui lui étaient attribués.
- Transférer les tâches et fichiers professionnels vers un espace contrôlé par l’entreprise.
- Conserver les journaux et documents nécessaires à l’audit.
- Vérifier les accès partagés et faire tourner les secrets auxquels la personne a pu avoir accès.
- Documenter la date, l’auteur et le motif de la révocation.

13. Exigences techniques d’implémentation

- Examiner l’architecture, la base de données, l’authentification et les fonctions existantes avant toute modification.
- Préserver les fonctionnalités existantes et éviter toute réécriture inutile.
- Créer des migrations versionnées et effectuer une sauvegarde avant les changements de schéma.
- Appliquer les contrôles d’autorisation côté serveur pour chaque route, action et ressource sensible.
- Refuser par défaut les accès non explicitement autorisés.
- Valider les entrées, protéger contre les attaques courantes et limiter les requêtes sensibles.
- Utiliser des transactions de base de données pour les opérations financières et les changements critiques.
- Fournir des messages d’erreur utiles sans révéler de secrets ni d’informations internes.
- Documenter les rôles, les permissions, les procédures de secours et les tests.

14. Tests d’acceptation obligatoires

- Un utilisateur standard ne peut pas modifier son rôle ou ses permissions sans autorisation.
- Le Greffier principal ne peut pas se promouvoir SUPER_ADMIN ni modifier le compte propriétaire.
- Aucun utilisateur non autorisé ne peut consulter les données financières ou personnelles protégées.
- Les modifications de permissions prennent effet côté serveur et sont consignées dans le journal.

- Les opérations financières sensibles nécessitent les approbations prévues.
- Les soldes et transactions ne peuvent pas être modifiés directement par une requête non autorisée.
- Les journaux d’audit ne peuvent pas être supprimés par les rôles ordinaires.
- La suspension d’un compte révoque effectivement ses sessions et accès actifs.
- Les sauvegardes peuvent être restaurées et les tests ne cassent pas les fonctionnalités existantes.
- Les contrôles sont testés sur l’API et le serveur, pas uniquement dans l’interface.

15. Livrables attendus

- Matrice des rôles et permissions par défaut.
- Écrans d’administration des utilisateurs, rôles et permissions.
- Tableau de bord propriétaire et tableau de bord Greffier principal.
- Workflow de validation des opérations financières sensibles.
- Journal d’audit consultable et protégé.
- Tests automatisés d’autorisation et de sécurité.
- Documentation technique, procédure de sauvegarde/restauration et procédure de départ d’un collaborateur.

16. Instruction à l’équipe technique ou à l’outil de développement

Avant de coder, analyser le projet existant et signaler les risques ou dépendances. Implémenter le système par étapes, avec sauvegardes et tests. Ne pas supprimer de fonctionnalités existantes. Si une exigence ne peut pas être appliquée exactement, expliquer la limitation et proposer une solution de sécurité équivalente. Les autorisations doivent être imposées côté serveur, pas seulement par l’affichage de boutons ou de menus.

Le résultat final doit permettre au propriétaire de gérer tous les accès depuis un point central, tout en empêchant les collaborateurs — y compris le Greffier principal — de prendre le contrôle du compte propriétaire, des actifs essentiels ou des finances de BILLOGRAPH.